

Advisory: Contractor Credential Abuse Leading to Ransomware

Advisory ID: ADV-2024-0917

Severity: high

Issued for: Water and wastewater utilities and their managed service providers

Summary

A regional water utility suffered a ransomware intrusion that began with a reused third-party maintenance credential lacking multi-factor authentication.

Background

The attacker authenticated to an internet-facing remote access portal on 4 September 2024 and maintained a low-profile foothold for eight days before escalating to domain administrator and deploying file-encrypting malware across eleven servers.

Initial access

A contractor credential unused for rotation in fourteen months and not protected by multi-factor authentication was used against an internet-facing remote access portal.

Lateral movement

A common open-source post-exploitation framework was used to reach a domain controller, where two rogue administrator accounts were created and network-share backups were deleted before encryption.

Affected entities

Corporate billing platform; Historian database; Nine additional Windows servers

Indicators

- domain: update-svc-sync.net (Command-and-control domain)
- ipv4: 185.220.101.47 (Attacker source address)
- sha256: 9f2c4e1a7b6d8c3f5a0e2d4b6c8a1f3e5d7c9b0a2e4f6d8c0b2a4e6f8d0c2b4a6 (Dropped payload)
- filename: RESTORE-FILES-NOW.txt (Ransom note)

Recommended actions

- [immediate] Rotate all contractor and third-party credentials and enforce multi-factor authentication on every remote access path.
- [high] Isolate backup infrastructure so that domain administrator accounts cannot reach or delete it.
- [medium] Deploy endpoint detection and response agents across all servers and engineering workstations.

References

- Internal incident report IR-2024-0917

Handling

For Official Use Only. Do not distribute outside partner utility security teams without originator approval.